

CS-AML

API Specification

Version 0.1.4

Approved Internal Specification Baseline

2026-10-10 · tag v0.1.4-spec

Civil Society Anti-Money Laundering & Financial Intelligence Framework

Generated from the canonical Markdown source. The Markdown file in the repository remains authoritative; change tags such as `[v0.1.x · ...]` are part of the traceability record.

Contents

Document Control	4
1. Scope and Boundary	5
2. API Design Principles	5
3. Base URL, Versioning and Media Type	5
4. Authentication and Principal Context	5
5. Common Headers and Correlation	7
6. Common Resource Envelope	7
7. Naming and Resource Conventions	8
8. Pagination, Sorting and Filtering	8
9. Error Model	9
10. Concurrency and Record Versioning	10
11. Idempotency	10
12. Case and Workflow API	11
13. Source, Evidence and File API	13
14. Entity, Relationship and Asset API	14
15. Timeline and Value Flow API	16
16. Typology, Hypothesis and Assessment API	17
16A. Claim and Fact API	19
17. Search API	20
18. Graph API	21
19. Product, Review and Dissemination API	22
20. Administration and Audit API	24
20A. Retention, Legal Hold and Disposition API [v0.1.3 · CR-17-01]	25
21. Protected Source API Boundary	26
22. Asynchronous Jobs	26
23. File Transfer and Content Safety	26
24. Bulk Operations	27
25. Rate Limiting and Abuse Controls	27
26. API Security Requirements	27
27. Audit Semantics	28
28. API Schema and OpenAPI Requirements	28

29. Compatibility and Deprecation	30
30. Verification and Contract Testing	30
31. API Definition of Done	31
Annex A — Canonical Resource Baseline	31
Annex B — Request Review Checklist	31

CS-AML

API Specification

Version 0.1.4

Document status — v0.1.4

Version: 0.1.4 — Approved Internal Specification Baseline (2026-10-10, tag v0.1.4-spec). Supersedes v0.1.3 (2026-10-09, tag v0.1.3-spec). [v0.1.4]

Supersedes: CS-AML API Specification v0.1. The DOCX/PDF files in this repository are the unchanged v0.1 baseline (legacy); this Markdown file is the canonical source.

Validation: approved by the product owner as the internal specification baseline on 2026-10-08 (v0.1.1) and 2026-10-09 (v0.1.2 and v0.1.3) and 2026-10-10 (v0.1.4; decision register and release gates in CHANGELOG.md). The v0.1.2, v0.1.3 and v0.1.4 changes come from change requests raised while implementing increments I1-I4, I5-I7 and the post-MVP follow-ups; this is not an independent audit. Acceptance criteria in this document are targets, not evidence that tests have passed.

CS-AML is not an external standard or certification. References to FATF, Wolfsberg, PPATK, UNODC or other bodies do not imply their endorsement.

Changes in 0.1.1: see CHANGELOG.md at the repository root (audit findings A01-A16).

Changes in 0.1.2: change requests CR-I1-01...CR-I4-14 approved by the product owner on 2026-10-09 (CHANGELOG.md, section v0.1.2). Each change is tagged *[v0.1.2 · CR-xx-yy]*.

Changes in 0.1.3: change requests CR-I5-01...CR-I7-08 approved by the product owner on 2026-10-09 (CHANGELOG.md, section v0.1.3). Each change is tagged *[v0.1.3 · CR-xx-yy]*.

Changes in 0.1.4: change requests CR-N-01...CR-N-14 approved by the product owner on 2026-10-10 (CHANGELOG.md, section v0.1.4). Each change is tagged *[v0.1.4 · CR-N-xx]*.

Purpose

Normative HTTP API baseline for CS-AML MVP 0.1 (approved internal specification baseline v0.1.1). [v0.1.1 · A01] It defines resource conventions, request/response envelopes, versioning, authorization behavior, filtering, pagination, concurrency, idempotency, uploads, search, graph projections, review/dissemination operations, errors, audit correlation and verification expectations.

Core API axiom

The API SHALL expose canonical data and authorized derived views without erasing provenance, uncertainty, version history or permission boundaries. It SHALL NOT convert candidate, reconstructed, hypothetical, inferred or derived data into stronger canonical truth through transport semantics.

Status: Normative API contract baseline for MVP 0.1 (approved internal specification baseline v0.1.1, 2026-10-08) [v0.1.1 · A01]

Dependencies: Framework v0.1.1 · Data Model v0.1.3 · SRS v0.1.3 · Technology Architecture v0.1.1 · Frontend Architecture v0.1.2 · Control Implementation Guide v0.1.3 (Markdown, Documents/*_v0.1.1.md) [v0.1.1 · A01]

Document Control

Attribute	Value
Document ID	CSAML-API-0.1
Version	0.1.4 [v0.1.4]
Status	Approved Internal Specification Baseline (2026-10-10, tag v0.1.4-spec) [v0.1.1 · A01]
Primary audience	Backend Engineer, Frontend Engineer, QA, Security Reviewer, Integration Engineer
Protocol	HTTPS + JSON; multipart/streaming where file transfer requires it
Reference style	Resource-oriented REST API with explicit action endpoints for workflow decisions
Normative verbs	SHALL / MUST / SHOULD / MAY

1. Scope and Boundary

This document defines the externally observable API contract for the CS-AML MVP. It does not require a particular backend framework or database schema. The canonical server implementation MAY use Django REST Framework or equivalent, but clients SHALL rely on the documented API rather than backend internals.

Authorization rule

Every API read, count, search result, relationship traversal, export candidate and mutation SHALL be permission-aware. UI behavior cannot broaden access.

2. API Design Principles

ID	Principle	Requirement
API-P01	Canonical resource first	Stable IDs identify canonical resources independent of UI route context.
API-P02	Context explicit	Case context, version and projection scope are explicit rather than inferred from browser state.
API-P03	Provenance preserved	Material analytical records expose provenance/evidence references appropriate to authorization.
API-P04	Uncertainty preserved	Unknown, disputed, candidate, reconstructed and hypothetical states are first-class values.
API-P05	Non-disclosing authorization	Denied requests SHALL not leak protected resource existence/content beyond policy.
API-P06	Version-aware mutation	Conflicting updates fail explicitly; no last-write-wins for material canonical records.
API-P07	Derived is labeled	Search, graph, path, summary and analytical projections are identified as derived/rebuildable.
API-P08	Audit correlation	Material requests have correlation/request IDs and auditable actor/action context.
API-P09	Predictable errors	Machine-readable error code + safe human message + field errors where relevant.
API-P10	Evolution controlled	Breaking changes require versioning/migration strategy.

3. Base URL, Versioning and Media Type

```
https://csaml.example.org/api/v1/
Accept: application/json
Content-Type: application/json
X-Request-ID: <optional-client-correlation-id>
X-CSRFToken: <django-csrf-token> # unsafe methods only (see §4)
```

- Initial major version SHALL be /api/v1/.
- Breaking field removals/semantic changes require a new major API version or documented compatibility period.
- Additive optional fields MAY be introduced within v1.
- Clients SHALL ignore unknown response fields unless schema validation explicitly disallows them for a security reason.
- The OpenAPI document (contracts/openapi.yaml, see §28) SHALL be versioned with application releases. [v0.1.1 · A11]

4. Authentication and Principal Context

Concern	Requirement
Authentication	Browser authentication is locked to a server-side session (BFF pattern). Django is a confidential OIDC client of Keycloak using Authorization Code + PKCE. Access, refresh and ID tokens stay server-side and are never exposed to JavaScript. Browsers SHALL NOT send Authorization: Bearer; bearer tokens from browsers are rejected. <i>[v0.1.1 · A11]</i>
Auth endpoints	GET /auth/login (redirect to IdP) · GET /auth/callback (code exchange, session creation) · POST /auth/logout (session destroyed; IdP logout initiated) · GET /auth/session (current principal, session expiry, coarse capabilities; 401 when no session). These are served by the same origin outside /api/v1. <i>[v0.1.1 · A11]</i> GET /auth/session additionally returns the optional fields username (display only, never an authorization identifier) and csrf_token. <i>[v0.1.2 · CR-11-07, CR-11-03]</i>
Back-channel logout	POST /auth/backchannel-logout implements OpenID Connect Back-Channel Logout 1.0: the IdP posts the form field logout_token (signed JWT); the server validates issuer, audience, signature and events claim and revokes the matching server-side sessions. The endpoint is authenticated by the signed token only (no session cookie, security: []) and is CSRF-exempt. Responses: 200 (sessions revoked or none matched), 400 (missing or invalid token). <i>[v0.1.2 · CR-11-05]</i>
Session cookie	The browser holds only __Host-csaml_session with attributes HttpOnly; Secure; SameSite=Lax; Path=/ and no Domain attribute. <i>[v0.1.1 · A11]</i>
CSRF	Every unsafe method (POST/PUT/PATCH/DELETE) SHALL carry the Django CSRF token in the X-CSRFToken header; missing/invalid token → 403. <i>[v0.1.1 · A11]</i> Delivery: the SPA reads the token from the csrf_token field of GET /auth/session; the CSRF secret is kept in the server-side session and no JavaScript-readable CSRF cookie exists. <i>[v0.1.2 · CR-11-03]</i>
Logout from the browser	A cross-origin 303 to the IdP end-session endpoint cannot be followed by fetch(), so the browser SHALL log out with a top-level form POST (application/x-www-form-urlencoded) to /auth/logout carrying the CSRF token as the form field csrfmiddlewaretoken. API clients and tests MAY send X-CSRFToken instead. The CSRF check and the 303 response are the same in both cases; the form field is accepted for this endpoint only. <i>[v0.1.2 · CR-11-04]</i>
Origin / CORS	The API is same-origin (/api/v1 behind Nginx). CORS is disabled by default. <i>[v0.1.1 · A11]</i>
Session timeouts	Idle and absolute session timeouts are security-policy configuration. <i>[v0.1.1 · A11]</i>
Principal	Server resolves user/service identity; client-submitted actor identity is not trusted.
MFA	Required claims/policy enforced server-side for sensitive actions where configured.
Step-up (MFA)	Keycloak levels of authentication: ACR 1 = password, ACR 2 = password + TOTP. GET /auth/login?acr=2&next=<path> requests a step-up (OIDC acr_values=2; next is a same-origin relative path, anything else becomes /); the callback records the verified acr and auth_time in the server-side session and audits auth.step_up. GET /auth/session adds auth_level, auth_time and step_up (enabled, required level, maximum age, stepped-up-at, valid-until, active, action list, login URL); these are UI hints, the server decides on every request. High-risk actions need ACR ≥ 2 within the step-up window (default 900 s): dissemination.approve (approveDissemination), export.generate (generateExportPackage), export.download (downloadExportPackage), disposition.approve, disposition.execute, legal_hold.release, entity.merge, entity.unmerge, gate.approve (approveCaseGate), protected_source.grant (createCaseMembership / updateCaseMembership granting or changing protected_source_authorized) and protected_source.access (searchObjects with include_source_protected=true and a grant; getEvidenceContent of SOURCE_PROTECTED evidence). Otherwise 403 STEP_UP_REQUIRED (§9) after the ordinary authorization checks (never disclosing an object), audited as auth.step_up_required. The contract marks these operations with x-csaml-step-up. Not step-up actions in v0.1.4: reading SOURCE_PROTECTED records other than evidence content, review approvals, membership revocation. Per-deployment action lists and phishing-resistant factors for approvers are deferred to v0.2. <i>[v0.1.4 · CR-N-13]</i>

Concern	Requirement
Login-callback errors	Every failed GET /auth/callback answers 303 to /?login_error=<reason>: expired (unknown or expired login state, e.g. a stale identity-provider tab), cancelled (the identity provider returned an error), failed (code rejected, token invalid, inactive principal) or unavailable (identity provider down). The cause is logged with the request id and never shown; the SPA explains the reason and offers a sign-in button and never restarts the login by itself. This replaces the 400 / 401 JSON errors of v0.1.3. [v0.1.4 · CR-N-14]
Service account	Machine/service API clients are out of MVP scope. When introduced, each SHALL be a distinct non-human principal with least privilege and no shared analyst identity; its authentication mechanism requires a separate decision. [v0.1.1 · A11]
Logout/revocation	After logout, session expiry or revocation, subsequent requests return 401. Keycloak back-channel logout SHOULD revoke the corresponding server-side sessions. [v0.1.1 · A11] It is delivered to POST /auth/backchannel-logout (above). [v0.1.2 · CR-I1-05]
Impersonation	Not supported in MVP unless separately controlled/audited.

5. Common Headers and Correlation

Header	Direction	Use
Cookie (__Host-csaml_session)	Request	Browser session authentication (§4). Authorization: Bearer is not accepted from browsers. [v0.1.1 · A11]
X-CSRFToken	Request	Django CSRF token; REQUIRED on every unsafe method (§4). [v0.1.1 · A11] Obtained from GET /auth/session (csrf_token); POST /auth/logout MAY carry it as the form field csrfmiddlewaretoken instead. [v0.1.2 · CR-I1-03, CR-I1-04]
X-Request-ID	Both	Correlation ID; server generates when absent.
ETag	Response	"<record_version>" returned on GET of every versioned resource (§10). [v0.1.1 · A04]
If-Match	Request	"<record_version>"; REQUIRED on mutations of versioned resources (§10). Missing → 428; stale → 412. [v0.1.1 · A04] Exception: multi-entity commands (merge, unmerge, POST /resolution-decisions, match-candidate decisions) send a body map expected_versions instead (missing → 428, mismatch → 412 with details. current_record_versions; §10, §14). [v0.1.1 · C03]
Idempotency-Key	Request	UUID; REQUIRED or SHOULD per §11. [v0.1.1 · A11]
Idempotent-Replayed	Response	true when the response is a replay of an earlier request with the same Idempotency-Key (§11). [v0.1.1 · A11]
Retry-After	Response	Rate limit/async polling guidance; also sent with 409 IDEMPOTENCY_IN_PROGRESS. [v0.1.1 · A11]
Content-Disposition	Response	Safe filename for export/download.

6. Common Resource Envelope

```
{
  "id": "uuid",
  "object_type": "entity",
  "schema_version": "1.0",
  "record_version": 7,
  "status": "ACTIVE",
  "classification": "RESTRICTED",
  "created_at": "2026-10-07T10:00:00Z",
  "created_by": {"id": "...", "display_name": "..."},
  "updated_at": "2026-10-07T11:12:00Z",
  "links": {...},
  "capabilities": ["read", "update", "link"]
}
```

Enum values and classification

Controlled enumeration values on the wire (including status) are UPPER_SNAKE_CASE machine values derived from the Data Model Annex A registry; display labels are separ-

ate and translatable. [v0.1.1 · A09] classification takes one of PUBLIC, INTERNAL, SENSITIVE, RESTRICTED, SOURCE_PROTECTED (least → most restrictive; display labels Public, Internal, Sensitive, Restricted, Source-protected). Access labels are additive restrictions; the most restrictive applicable level plus all labels apply. Derived objects and exports inherit the highest classification of their inputs unless a recorded reviewer downgrade decision exists. A resource with unknown or missing classification fails closed (access denied; flagged for classification). [v0.1.1 · A08]

Classification inheritance and case links [v0.1.2 · CR-I2-05, CR-I2-01, CR-I3-13, CR-I4-12]

A create request whose declared classification is below the highest classification of its inputs, or whose access_labels miss a label of an input, is rejected with 422; omitted fields default to the inherited value. PATCH may only upgrade the classification or add labels; downgrades and label removal → 403 until a recorded reviewer decision exists. When an input is later upgraded, dependent objects are flagged for re-review; their classification is never raised automatically. [v0.1.2 · CR-I2-05]

Every create request that carries case_links SHALL send it with 1..20 case IDs (sources, upload sessions, entities, relationships, value flows, hypotheses, assessments, intelligence products, assets, ownership interests, control assertions, events, indicators, typology matches, intelligence gaps); missing or empty → 422. The creator needs case.update on every named case (404/403, non-disclosing). An object without case context would be reachable by no one. Extracts and derivatives inherit the parent's links; claims, facts and decisions belong to their path case. [v0.1.2 · CR-I2-01, CR-I3-13, CR-I4-12]

Classes without their own lifecycle carry the registry enum envelope_status in status: REGISTERED (Source, EvidenceExtract, Asset), RECORDED (Event, ValueFlow, TypologyMatch), DRAFT/FINALIZED (Assessment until a review outcome, then its review_status). Classes with a lifecycle mirror it (claim_status, fact_status, resolution_status, relationship_status, ...). [v0.1.2 · CR-I2-03, CR-I3-05, CR-I4-09]

Capabilities

capabilities MAY help the UI render permitted actions, but SHALL NOT replace server authorization. Capabilities are contextual and may change between requests.

7. Naming and Resource Conventions

Rule	Convention
Collection names	Plural kebab-case or consistent plural nouns: /cases, /entities, /value-flows.
IDs	Opaque stable UUID-like identifiers; clients do not parse meaning from IDs.
Timestamps	ISO 8601 UTC in transport; original timezone may be additional metadata.
Enums	Stable UPPER_SNAKE_CASE machine values derived from the Data Model Annex A registry; user-facing localized labels are separate. [v0.1.1 · A09]
Unknown	Use null/explicit status per schema; never substitute 0/false/empty string when semantically different.
Money	Amount + currency; ranges preserve min/max/approximate/original value semantics.
Dates	Precision field accompanies partial/approximate dates where domain requires it.
Relationships	First-class resource, not hidden nested-only edge.

8. Pagination, Sorting and Filtering

```
GET /api/v1/entities?case_id=...&type=ORGANIZATION&resolution_status=RESOLVED&classification=RESTRICTED,SOURCE_PROTECTED&
  sort=-updated_at&page[size]=50&page[after]=...
```

Filter values are registry wire values: type is an entity_type, resolution_status an entity_resolution_status (schemas/enums.yaml). [v0.1.1 · C14]

Concern	Baseline
Pagination	Cursor-based SHOULD be preferred for mutable large collections; page-number MAY be used for stable admin lists.
Page size	Default 50; max configurable. Server MAY lower for expensive resources.
Sorting	Explicit allowlist only; deterministic secondary sort.
Filtering	Typed documented filters; no arbitrary raw SQL/query expressions.
Facets	Server computes permission-aware facets/counts.
Total count	MAY be omitted/approximate for expensive permission-filtered queries; semantics documented.
Search query	Input length/rate limits apply; results never reveal unauthorized counts/snippets.

9. Error Model

```
{
  "error": {
    "code": "PRECONDITION_FAILED",
    "message": "The record changed after you opened it.",
    "request_id": "req...",
    "details": {"current_record_version": 8},
    "field_errors": {}
  }
}
```

HTTP	Example code	Semantics
400	INVALID_REQUEST	Malformed/semantically invalid request not tied to one field.
401	AUTHENTICATION_REQUIRED	No valid authenticated principal.
403/404	ACCESS_DENIED / NOT_FOUND	Deployment/policy chooses non-disclosing behavior consistently.
403	STEP_UP_REQUIRED	High-risk action without a recent second-factor verification (§4); details: reason (STEP_UP_MISSING / STEP_UP_EXPIRED), action, required_acr, max_age_seconds, step_up_url. [v0.1.4 · CR-N-13]
409	STATE_CONFLICT	Workflow/business-state conflict only (e.g. gate not satisfied, object already finalized, approving a rejected item). Not used for stale versions. [v0.1.1 · A04]
409	IDEMPOTENCY_IN_PROGRESS	A request with the same Idempotency-Key is still in flight; Retry-After included (§11). [v0.1.1 · A11]
412	PRECONDITION_FAILED	If-Match does not match the current record_version; details.current_record_version included. No silent overwrite. [v0.1.1 · A04] Multi-entity commands (§10, §14): an expected_versions entry does not match; details.current_record_versions (map of entityId → current record_version) included. [v0.1.1 · C03]
422	VALIDATION_FAILED	Field/domain validation.
422	IDEMPOTENCY_KEY_REUSED	Same Idempotency-Key reused with a different payload (§11). [v0.1.1 · A11]
428	PRECONDITION_REQUIRED	Mutation of a versioned resource sent without If-Match. [v0.1.1 · A04] Multi-entity commands (§10, §14): expected_versions missing or not covering every subject entity. [v0.1.1 · C03]
429	RATE_LIMITED	Request rate or expensive operation threshold exceeded.
500	INTERNAL_ERROR	Safe generic message; request ID for support.
503	DEPENDENCY_UNAVAILABLE	Temporary backend dependency failure.

The error code VERSION_CONFLICT used in v0.1 is retired; stale versions are reported only as 412 PRECONDITION_FAILED, which clients map to the “record changed” recovery UI. [v0.1.1 · A04]

Evaluation order. The server SHALL evaluate a request in this order and return the first failure: authentication (401) → authorization (403/404, non-disclosing) → header validation (400/428) → precondition (412) → body validation (422) → workflow state (409). [v0.1.1 · A04]

The error envelope above (error.code, message, request_id, details, field_errors) is the normative error envelope for v1. [v0.1.1 · A11]

Error safety

Error payloads SHALL not include raw SQL, stack traces, filesystem paths, evidence snippets, protected-source identity or authorization-policy internals.

10. Concurrency and Record Versioning

- Material mutable resources SHALL expose `record_version` or equivalent concurrency token.
- Versioned resources SHALL return `Etag`: "`<record_version>`" on GET. *[v0.1.1 · A04]*
- Mutations of versioned resources (PATCH/PUT/DELETE and state-changing commands on a versioned resource) SHALL send `If-Match`: "`<record_version>`". Missing `If-Match` → **428 PRECONDITION_REQUIRED**. *[v0.1.1 · A04]* Exception: multi-entity commands (merge, unmerge, POST /resolution-decisions, match-candidate decisions) send a body map `expected_versions` instead (missing → 428, mismatch → 412 with `details.current_record_versions`; §10, §14). *[v0.1.1 · C03]*
- Stale `If-Match` → **412 PRECONDITION_FAILED** with `details.current_record_version` and other safe metadata needed for recovery; the API SHALL NOT silently overwrite. *[v0.1.1 · A04]*
- A `record_version` in the body is optional; if present it SHALL equal the `If-Match` value, otherwise **400 INVALID_REQUEST**. *[v0.1.1 · A04]*
- 409 STATE_CONFLICT** is reserved for workflow/business-state conflicts. Approvals, merges, dissemination and assessment finalization SHALL validate both the precondition (412) and current workflow state (409), in the evaluation order of §9. *[v0.1.1 · A04]*
- A retried request carrying the same `Idempotency-Key` replays the original result (§11) instead of failing with 412. *[v0.1.1 · A04, A11]*
- Commands that mutate several versioned resources at once (entity merge/unmerge, resolution decisions and match-candidate decisions, §14) carry their preconditions in a body map `expected_versions` instead of `If-Match`: missing or incomplete → 428, mismatch → 412 with `details.current_record_versions`. An RFC 9110 `If-Match` list passes if any single tag matches, so it cannot guard several resources. *[v0.1.1 · A04]* The map is checked in the precondition step of §9 and is therefore not listed as required in the JSON schema, so that a missing map yields 428, not 422. *[v0.1.1 · C03]*
- Immutable/audit resources reject ordinary update/delete methods.

```
PATCH /api/v1/assessments/{id}
If-Match: "7"
{ "record_version": 7, "judgement": "..." }

→ 412 PRECONDITION_FAILED if current version is 8
{ "error": { "code": "PRECONDITION_FAILED", "details": {"current_record_version": 8}, ... } }
→ 428 PRECONDITION_REQUIRED if If-Match is absent
```

[v0.1.1 · A04]

11. Idempotency

Locked semantics: *[v0.1.1 · A11]*

Aspect	Rule
Header	<code>Idempotency-Key</code> : <UUID>
Scope	(principal, HTTP method, route template + path parameters).
Retention	24 hours from the first request.
Same key + same payload hash	Replay the original status and body with response header <code>Idempotent-Replayed</code> : true.
Same key + different payload	422 IDEMPOTENCY_KEY_REUSED .

Aspect	Rule
Same key while the first request is in flight	409 IDEMPOTENCY_IN_PROGRESS with Retry-After.
Interaction with If-Match	A replay returns the original result; it does not re-evaluate the precondition and does not fail with 412.

Operation	Idempotency requirement
Normal PATCH with version token	If-Match protection (§10) generally sufficient; Idempotency-Key MAY be sent. <i>[v0.1.1 · A11]</i>
Create case/entity (and other creates)	Idempotency-Key SHOULD be sent. <i>[v0.1.1 · A11]</i>
Evidence ingest finalization	Idempotency-Key REQUIRED. <i>[v0.1.1 · A11]</i>
Merge/unmerge	Idempotency-Key REQUIRED. <i>[v0.1.1 · A11]</i>
Approve review/dissemination	Idempotency-Key REQUIRED; a repeat SHALL return the same completed decision, never a duplicate decision. <i>[v0.1.1 · A11]</i>
Export package generation	Idempotency-Key REQUIRED; ties a retry to the same approved package request. <i>[v0.1.1 · A11]</i>

The response code for a request that omits a REQUIRED Idempotency-Key is not yet locked (open item, §28). *[v0.1.1 · A11]*

12. Case and Workflow API

Method	Endpoint	Purpose
GET	/cases	Authorized case register.
POST	/cases	Create case.
GET	/cases/{caseId}	Canonical case detail.
PATCH	/cases/{caseId}	Version-aware case update.
GET	/cases/{caseId}/charter	Current charter + version history links.
POST	/cases/{caseId}/charter/versions	Create new charter version.
GET	/cases/{caseId}/charter/versions	Charter version history, oldest first (listCharterVersions). <i>[v0.1.4 · CR-N-01]</i>
GET	/cases/{caseId}/charter/versions/{version}	One charter version (getCharterVersion; target of version_links). <i>[v0.1.4 · CR-N-01]</i>
GET	/cases/{caseId}/gates	Lifecycle gates.
POST	/cases/{caseId}/gates/{gateId}/submit	Submit gate for decision.
POST	/cases/{caseId}/gates/{gateId}/approve	Independent approval action.
POST	/cases/{caseId}/gates/{gateId}/reject	Reject/return with rationale.
GET	/cases/{caseId}/tasks	Tasks.
POST	/cases/{caseId}/tasks	Create task.
GET/PATCH	/tasks/{taskId}	Task with history (getTask); assign, reschedule or move the status (updateTask, If-Match). <i>[v0.1.4 · CR-N-01, CR-N-04]</i>
GET	/cases/{caseId}/activity	Material case activity projection.
GET/POST	/cases/{caseId}/memberships	List active memberships; grant a membership (principal_id, role = LEAD/ANALYST/REVIEWER, protected_source_authorized). An active membership for the same principal → 409. <i>[v0.1.2 · CR-I1-02]</i>
PATCH/DELETE	/case-memberships/{membershipId}	Change role or protected-source grant; revoke (soft: revoked_at, 204). If-Match REQUIRED. The LEAD membership cannot be revoked (409). <i>[v0.1.2 · CR-I1-02]</i>
GET	/cases/{caseId}/graph	Per-case graph projection (§18). <i>[v0.1.2 · CR-I3-07]</i>

Concern	Rule
Investigation questions	Case.investigation_questions may be empty while the case is DRAFT (questions are created through the charter). At least one question is a precondition of case activation (gate), not of the response schema (SRS-FR-CASE-001). [v0.1.2 · CR-I1-01]
Value sets	risk_rating: LOW, MEDIUM, HIGH, CRITICAL; closure_reason: OBJECTIVES_MET, INSUFFICIENT_BASIS_TO_CONTINUE, REFERRED, OUT_OF_SCOPE, DUPLICATE, LEGAL_OR_SAFETY_CONSTRAINT, OTHER (registry schemas/enums.yaml). [v0.1.2 · CR-I1-08]
Classification change	Only the case LEAD may change a case's classification or access_labels via PATCH / cases/{caseId}, and only upwards (higher level, added labels). Downgrades and label removal require a recorded reviewer decision (workflow delivered with review, I6) and are rejected with 403 until then. [v0.1.2 · CR-I1-09]
Memberships	Managed by the case LEAD (403 otherwise). A case keeps exactly one LEAD; the lead changes through PATCH /cases/{caseId} (lead_analyst_id). protected_source_authorized is effective only for principals holding the IdP eligibility role csaml-protected-source. Every grant, change and revocation is audited. [v0.1.2 · CR-I1-02, CR-I1-10]
Charter	Append-only CharterVersion (Data Model §6.4): purpose, investigation questions (priority PRIMARY / SECONDARY, registry investigation_question_priority) and the Framework Annex A fields (trigger, public-interest rationale, scope included / excluded, initial subjects and hypotheses, expected sensitive data, legal basis, legal / privacy constraints, security / source risks, harm assessment, authorised / prohibited collection methods, expected outputs, stop conditions, jurisdictions, time period, review date). A question sent with id keeps that question; a question left out of a later version is RETIRED, never deleted. change_rationale is REQUIRED for every version after the first (422). Charter adds versions, approved_version (the version bound by the approved G1) and amended_since_approval. [v0.1.4 · CR-N-01, CR-N-02]
Gates	Seven gates G0-G6 per case; status (registry gate_status) NOT_SUBMITTED → SUBMITTED → APPROVED / REJECTED, REJECTED → SUBMITTED, APPROVED final. Case status changes only through an approved gate: G0 DRAFT → AUTHORIZED, G1 AUTHORIZED → ACTIVE, G4 ACTIVE → REVIEW, G6 ACTIVE / REVIEW → CLOSED (with closure_reason, REQUIRED to submit G6); G2, G3 and G5 change no status. MONITORING and REOPENED are not reachable through the API in v0.1.x (v0.2). Gate adds gate_status, title, decision_question, transition, preconditions, submitter / decider fields, conditions and the decision history; GateDecisionRequest adds conditions (CIG CAS-02) and closure_reason. [v0.1.4 · CR-N-01, CR-N-03]
Gate readiness criteria	Checked by the system at submission and again at approval (unmet → 409 with the codes): case status; previous gate approved (G2-G5); G0 charter recorded, trigger and public-interest rationale; G1 ≥ 1 investigation question, scope, time period, jurisdictions, expected data, harm assessment; G2 legal basis and authorised collection methods; G3 evidence linked and gaps recorded; G4 an assessment and ≥ 2 hypotheses; G5 an independently approved product version; G6 a closure reason. Everything else in Framework §5 / Methodology §3 is reviewer judgement recorded in the decision rationale or enforced by other controls (Framework §5.9). Gates control the case lifecycle only (activation, review, closure); collection, assessment finalisation and dissemination keep their own controls and are not blocked by gate state. Configuration per organisation or risk tier is deferred to v0.2. [v0.1.4 · CR-N-05, CR-N-06]
Gate independence	The decider is never the submitter (403; database CHECK). Deciders are LEAD or REVIEWER members (gate.decide). For a high-impact case — risk HIGH / CRITICAL, or classification RESTRICTED / SOURCE_PROTECTED — the G0 / G1 decider must not have authored the charter version under approval (403). Gate approval is a step-up action (§4). [v0.1.4 · CR-N-07, CR-N-13]
Tasks	task_type (registry): COLLECTION, VERIFICATION, ANALYSIS, REVIEW, OTHER; task_status (registry): OPEN, IN_PROGRESS, BLOCKED, DONE, CANCELLED (DONE and CANCELLED final, database-guarded; 409 TASK_CLOSED). The assignee is an active, eligible case member (422); dependencies are tasks of the same case and DONE needs every dependency closed (409 DEPENDENCIES_OPEN). Members with case.update change any field; the assignee may change only the status of their own task. History is append-only. Links from tasks to sources, entities and hypotheses are deferred to v0.2. [v0.1.4 · CR-N-04]

Concern	Rule
Activity	Server side: permission filter (case-level targets and readable objects; no authz.* / auth.* / security.* events; references only), sort=occurred_at / -occurred_at, classification filter; items add target_type, audit_action and links. Actor / action / object filters run client-side on the loaded page; server parameters (actor, action, target_type) and an auditor view are deferred to v0.2. <i>[v0.1.4 · CR-N-01, CR-N-08]</i>

13. Source, Evidence and File API

Method	Endpoint	Purpose
GET/POST	/sources	Register/query sources.
GET/ PATCH	/sources/{sourceId}	Source detail/update.
GET	/evidence	Authorized evidence library.
POST	/evidence/uploads	Initiate upload session.
PUT	/evidence/uploads/{uploadId}/content	Stream/upload bytes (PUT only). <i>[v0.1.1 · C18]</i>
POST	/evidence/uploads/{uploadId}/complete	Finalize immutable evidence record and hash.
GET	/evidence/{evidenceId}	Evidence metadata.
GET	/evidence/{evidenceId}/content	Authorized content stream/download; supports range where safe. An invalid Range → 400 (no 416). <i>[v0.1.2 · CR-I2-02]</i> An original whose stored bytes were purged by an executed DELETE disposition (\$20A) → 409 STATE_CONFLICT, details.reason = "EVIDENCE_DISPOSED"; the metadata record stays as the tombstone. <i>[v0.1.3 · CR-I7-07]</i>
POST	/evidence/{evidenceId}/verify-integrity	Recompute/verify integrity.
GET/POST	/evidence/{evidenceId}/extracts	List the readable extracts of an evidence item; create citation/extract. <i>[v0.1.2 · CR-I2-06]</i>
GET	/evidence-extracts/{extractId}	Canonical single-extract resource (getEvidenceExtract): the extract's links.self and the back-link used by search hits, product citations and provenance traces; readable exactly when the parent evidence item is readable (non-disclosing 404 otherwise); links.evidence points to the parent. <i>[v0.1.3 · CR-I5-07]</i>
GET	/evidence/{evidenceId}/lineage	Original/derivative lineage.
POST	/evidence/{evidenceId}/text-extractions	Queue OCR / text extraction (requestTextExtraction; 202 + job, Idempotency-Key REQUIRED). <i>[v0.1.4 · CR-N-09]</i>
POST	/evidence/{evidenceId}/translations	Queue an offline machine translation of the item's text (requestEvidenceTranslation; 202 + job). <i>[v0.1.4 · CR-N-10]</i>
GET	/evidence/{evidenceId}/derived-texts	Derived texts of the item's lineage (listEvidenceDerivedTexts; page text omitted). <i>[v0.1.4 · CR-N-09]</i>
GET	/derived-texts/{derivedTextId}	One derived text with its pages (getDerivedText). <i>[v0.1.4 · CR-N-09, CR-N-10]</i>
POST	/derived-texts/{derivedTextId}/translations	Queue a translation of a completed OCR / extraction output (requestDerivedTextTranslation; 202 + job). <i>[v0.1.4 · CR-N-10]</i>
POST	/derived-texts/{derivedTextId}/review	Record a human review (reviewDerivedText; If-Match). <i>[v0.1.4 · CR-N-09, CR-N-10]</i>
POST	/evidence/{evidenceId}/derivatives	Register approved derivative metadata/output. The bytes come from an upload session whose content upload has completed (CONTENT_RECEIVED, not yet completed); registering the derivative finalizes that session. <i>[v0.1.2 · CR-I2-02]</i>

Evidence invariant

File upload success SHALL NOT by itself mean evidence is complete. The completion endpoint SHALL only succeed after required metadata, storage write and integrity record succeed atomically or with documented compensating behavior.

Concern	Rule
Upload session	status: INITIATED → CONTENT_RECEIVED (after PUT .../content) → COMPLETED (completed into an EvidenceItem, or consumed by a derivative registration). Responses add received_size_bytes and detected_media_type. Sessions are private to their initiator (404 for others) and expire after 24 h (expires_at; there is no expired status). A size-limit violation or an empty body → 422 (no 413). [v0.1.2 · CR-I2-02]
EvidenceItem fields	Responses add byte_size, hash_algorithm, derived_from and derivation_type (free text in v0.1.2; since v0.1.4 the registered open vocabulary derivation_type: OCR_TEXT, TEXT_EXTRACTION, MACHINE_TRANSLATION are produced only by the derived-text worker, other UPPER_SNAKE_CASE values such as REDACTION are accepted [v0.1.4 · CR-N-09]). storage_ref is the opaque evidence:<id>; bucket and key are never disclosed. [v0.1.2 · CR-I2-06]
Status	Source and EvidenceExtract carry envelope status = REGISTERED (§6). [v0.1.2 · CR-I2-03]
Derived text (OCR, extraction)	A DerivedText (Data Model §7.7) records one automated transformation: transformation OCR / TEXT_EXTRACTION (registry derived_text_transformation), engine and version, languages, models with SHA-256 and licence, per-page text with page mapping, method (registry text_page_method) and mean OCR word confidence (not an analytical confidence), content and input SHA-256; status (registry derived_text_status) QUEUED → PROCESSING → REVIEW_REQUIRED → REVIEWED, or FAILED with a safe error code. The worker reads the pinned original, re-hashes it first (mismatch → FAILED) and stores the output also as a new derivative EvidenceItem (derivation_type OCR_TEXT / TEXT_EXTRACTION); the original is only read. Classification, labels and case links are inherited from the input. Requesting needs update rights on the item; review needs a LEAD, ANALYST or REVIEWER membership; review never turns derived text into the original or into a fact. 409: FEATURE_DISABLED, UNSUPPORTED_FORMAT, ALREADY_DERIVED_TEXT. Automatic extraction after ingest is optional and off by default. [v0.1.4 · CR-N-09, CR-N-12]
Machine translation	Translations are DerivedTexts with transformation MACHINE_TRANSLATION, source and target language (id → en, en → id; 422 otherwise), produced offline only — no evidence content leaves the host, there is no online fallback (§26, Technical Stack §9). Every page keeps its source-language text; the label reads "Machine translation — review required" until a person reviews it and "reviewed by a person (still a translation)" afterwards; an intelligence product that uses a translation carries the machine-translation label. A translation is never translated again (409 TRANSLATION_OF_TRANSLATION); lineage: translation → OCR / extraction derivative → original. No second reviewer is required. [v0.1.4 · CR-N-10, CR-N-12]

14. Entity, Relationship and Asset API

Method	Endpoint	Purpose
GET/POST	/entities	Authorized entity search/register/create.
GET/ PATCH	/entities/{entityId}	Canonical entity detail/update.
GET	/entities/{entityId}/identifiers	Identifiers/aliases with provenance.
GET	/entity-match-candidates	Candidate duplicates.
POST	/entity-match-candidates/{id}/decisions	Deprecated in v0.1.2, removal in v0.2; use POST /resolution-decisions, which records the same decision with identical semantics. [v0.1.2 · CR-I2-14] Record a ResolutionDecision on the candidate's subject entities with wire value KEEP_SEPARATE (distinct), POSSIBLE_MATCH (possible) or DEFER (unresolved or deferred; Methodology §12.2 maps UNRESOLVED → DEFER). A same-entity outcome is recorded as MERGE through POST /entities/merge, not here. [v0.1.1 · ER] [v0.1.1 · C06]
POST	/entities/merge	Version-aware merge action; creates a MERGE ResolutionDecision. [v0.1.1 · ER]
POST	/entity-merges/{mergeId}/unmerge	Controlled reversal; {mergeId} is the id of the MERGE ResolutionDecision; creates an UNMERGE ResolutionDecision with reverses_decision_ref = {mergeId}. [v0.1.1 · ER]
GET	/entities/{entityId}/resolution-decisions	Append-only ResolutionDecision history for the entity. [v0.1.1 · ER]

Method	Endpoint	Purpose
GET	/entities/{entityId}/provenance	Provenance trace (nodes, edges, every path back to a Source; unreadable nodes omitted without disclosure). <i>[v0.1.2 · CR-I2-04]</i>
POST	/resolution-decisions	Record a POSSIBLE_MATCH, KEEP_SEPARATE or DEFER ResolutionDecision. MERGE/UNMERGE are rejected here (422) and use the commands above. <i>[v0.1.1 · ER]</i> This is the single endpoint for non-structural decisions. <i>[v0.1.2 · CR-I2-14]</i>

Concern	Rule <i>[v0.1.1 · ER]</i>
ResolutionDecision	Fields per Data Model §8.4: subject_entity_refs (2..n), decision (MERGE, KEEP_SEPARATE, POSSIBLE_MATCH, DEFER, UNMERGE), surviving_entity_ref (required for MERGE), reverses_decision_ref (required for UNMERGE), matching_attributes, conflicting_attributes, evidence_refs (1..n; EvidenceExtract, EvidenceItem or Source, readable and in the case context, otherwise 422 <i>[v0.1.2 · CR-I2-07]</i>), confidence, rationale, decided_by / decided_at (server-resolved), reviewer_ref (required for every MERGE/UNMERGE, all of which are high-impact in the MVP — missing → 422; SHALL be a principal holding REVIEWER or LEAD membership on every subject entity's case, otherwise 422; SHALL differ from decided_by, otherwise 409 STATE_CONFLICT <i>[v0.1.2 · CR-I2-09, CR-I2-10]</i>). Append-only: no PATCH/DELETE; corrections are new decisions. Missing conditional fields → 422.
Entity state	resolution_status (UNRESOLVED, RESOLVED, CONFLICTED, MERGED, SPLIT) is read-only on PATCH /entities/{entityId}; it changes only as the effect of a ResolutionDecision (Data Model §8.4, DM-I15).
Preconditions	Multi-entity commands (POST /entities/merge, POST /entity-merges/{mergeId}/unmerge, POST /resolution-decisions, POST /entity-match-candidates/{id}/decisions) SHALL send a body map expected_versions: {<entityId>: <record_version>} covering every subject entity (checked as a precondition, not as a schema-required field; §10). <i>[v0.1.1 · C03]</i> Missing map (or a subject entity missing from it) → 428 PRECONDITION_REQUIRED; any mismatch → 412 PRECONDITION_FAILED with details.current_record_versions (map of entityId → current record_version). An If-Match header is not used for these commands: under RFC 9110 an If-Match list passes if any single tag matches, so it cannot guard several resources at once. <i>[v0.1.1 · A04]</i> Idempotency-Key REQUIRED for MERGE/UNMERGE (§11), SHOULD for other decisions.
Re-suggestion	A pair with a KEEP_SEPARATE decision SHALL NOT reappear in /entity-match-candidates unless new evidence is attached to either subject.
Merge model	Merge is logical repointing via canonical_parent: relationships, claims and absorbed records are never rewritten. Unmerge therefore re-attributes nothing; it removes what the merge added to the survivor and restores its prior handling. History is never erased. <i>[v0.1.2 · CR-I2-13]</i>

Relationship and asset endpoints: *[v0.1.1 · C07]*

Method	Endpoint	Purpose
GET/POST	/relationships	First-class relationships. GET accepts the filter entity_id (relationships where the entity or asset is either endpoint). <i>[v0.1.2 · CR-I2-06, CR-I3-08]</i>
GET/ PATCH	/relationships/{relationshipId}	Relationship detail/update.
GET	/relationships/{relationshipId}/provenance	Provenance trace (as above). <i>[v0.1.2 · CR-I2-04]</i>
GET/POST	/assets	Asset registry. <i>[v0.1.2 · CR-I3-01]</i>
GET/ PATCH	/assets/{assetId}	Asset detail/update (ETag/If-Match). <i>[v0.1.2 · CR-I3-01]</i>
GET/POST	/ownership-interests	OwnershipInterest (Data Model §9.2); creates the OWNS/BENEFICIAL_OWNER_OF edge unless relationship_ref names a matching one. <i>[v0.1.2 · CR-I3-01]</i>
GET/ PATCH	/ownership-interests/{interestId}	Detail/update (ETag/If-Match). <i>[v0.1.2 · CR-I3-01]</i>

Method	Endpoint	Purpose
GET/POST	/control-assertions	ControlAssertion (Data Model §9.3); controlled_entity may name an Asset. <i>[v0.1.2 · CR-I3-01]</i>
GET/ PATCH	/control-assertions/{assertionId}	Detail/update (ETag/If-Match). <i>[v0.1.2 · CR-I3-01]</i>
GET	/assets/{assetId}/provenance · / ownership-interests/{interestId}/ provenance · /control-assertions/ {assertionId}/provenance	Provenance traces. <i>[v0.1.2 · CR-I3-08]</i>

Concern	Rule
Evidence targets	Relationship.supporting_evidence: EvidenceExtract, EvidenceItem or Fact. Asset evidence: Source, EvidenceItem or EvidenceExtract; OwnershipInterest/ControlAssertion evidence: EvidenceExtract, EvidenceItem or Fact. Every reference must be readable and share the case context (422 otherwise, non-disclosing). <i>[v0.1.2 · CR-I2-07, CR-I3-01]</i>
Asset targets	to_entity may reference an Asset; responses state to_object_type (Entity or Asset). Directly via POST /relationships only USES, MANAGES and ACQUIRED may target an asset; OWNS, BENEFICIAL_OWNER_OF and CONTROLS to an asset only together with an OwnershipInterest or ControlAssertion (422 otherwise). <i>[v0.1.2 · CR-I3-08]</i>
Established ownership Status	BENEFICIAL, ECONOMIC_INTEREST and NOMINEE_ASSERTED interests become ESTABLISHED only with an ESTABLISHED Fact in supporting_evidence (422 otherwise). <i>[v0.1.2 · CR-I3-11]</i> Asset envelope status = REGISTERED; OwnershipInterest/ControlAssertion mirror interest_status/assertion_status (relationship_status values). <i>[v0.1.2 · CR-I3-05]</i>

15. Timeline and Value Flow API

Method	Endpoint	Purpose
GET/POST	/events	Events with temporal precision; filters entity_id, asset_id, type, from/to (overlap). Event adds description, approximate, asset_refs; time_precision from registry temporal_precision; start_time is null only with UNKNOWN. <i>[v0.1.2 · CR-I3-02, CR-I3-06]</i>
GET/ PATCH	/events/{eventId}	Event detail/update (ETag/If-Match). <i>[v0.1.2 · CR-I3-02]</i>
GET	/timeline	Derived timeline projection; case_id required; also lists dated value flows with their class; undated items separately in undated[]. <i>[v0.1.2 · CR-I3-02]</i>
GET/POST	/value-flows	ValueFlow resources.
GET/ PATCH	/value-flows/{flowId}	Flow detail/update.
POST	/value-flows/{flowId}/ legs	Add version-aware flow leg. Legs are immutable: there is no leg update or delete. <i>[v0.1.2 · CR-I3-04]</i>
GET	/value-flow-view	Derived projection for the workspace (case_id required): flows with legs, per-class aggregates, legend, meta.derived. <i>[v0.1.2 · CR-I3-03]</i>
GET	/value-flow-legend	The four classes with label, text cue, line style, meaning and evidence rule. <i>[v0.1.2 · CR-I3-03]</i>
GET	/events/{eventId}/ provenance · / value-flows/{flowId}/ provenance	Provenance traces. <i>[v0.1.2 · CR-I3-08]</i>

Flow semantics

Every ValueFlow response SHALL carry its epistemic class in flow_class with one of the wire values DIRECT, DOCUMENTED, RECONSTRUCTED, HYPOTHETICAL (UPPER_SNAKE_CASE; from the Data Model Annex A registry). *[v0.1.1 · A09]* No endpoint may collapse these into a generic “transaction” representation.

Concern	Rule
Legs	Each leg keeps its own evidence, class, value and confidence: ValueFlowLeg adds reconstruction_basis (required for RECONSTRUCTED/HYPOTHETICAL legs) and confidence; responses add origin_type, destination_type, amount_kind, flow_class_label, and the flow adds chain{leg_count, leg_classes, mixed_classes, complete}. Legs are append-only, appended in order (sequence = n + 1), each starting where the previous one ended; a complete chain takes no more legs (409); endpoints of a chained flow are fixed (409); leg inputs may not exceed the flow's classification. [v0.1.2 · CR-I3-04]
Certainty order	Used only for invariants, never displayed, averaged or summed (the registry stays unordered): HYPOTHETICAL < RECONSTRUCTED < DOCUMENTED < DIRECT. A flow_class change that raises certainty must add at least one evidence reference not previously attached (422); a flow is never stronger than its weakest leg (422); lowering must meet the target class's requirements. [v0.1.2 · CR-I3-09]
Evidence targets	Flow, leg and event evidence: EvidenceExtract, EvidenceItem or Fact, readable and in the case context. DIRECT and DOCUMENTED need at least one EvidenceItem or EvidenceExtract (a Fact alone → 422). [v0.1.2 · CR-I3-10]
Aggregation	GET /value-flow-view groups flows by (flow_class, flow_type, currency); there is no grand total. CONTRACT/SUBCONTRACT groups are value_nature: OBLIGATION; only DIRECT groups are settlement_evidenced. Each group has lower_bound_total, upper_bound_total (null if any amount is unknown or open-ended) and exact_total (only when every amount is a known exact point); unknown amounts are null, counted and never treated as 0; legs are never added to their flow's totals. [v0.1.2 · CR-I3-12]
Status	Event and ValueFlow envelope status = RECORDED. [v0.1.2 · CR-I3-05]

16. Typology, Hypothesis and Assessment API

Method	Endpoint	Purpose
GET	/typology-catalogue	Loaded catalogue versions, notice, publication register, origin/verification counts. [v0.1.2 · CR-I4-01]
GET	/typologies	Versioned typology catalogue (filters: family, status, text, version). [v0.1.2 · CR-I4-01]
GET	/typologies/{typologyId}	Typology version/detail (?version=), every indicator with its A13 origin, verification_status and lineage as stated. Read-only reference data; any signed-in principal may read it. [v0.1.2 · CR-I4-01]
GET/POST	/indicators	Evidence-linked indicators/counter-indicators. [v0.1.2 · CR-I4-02]
GET/ PATCH	/indicators/{indicatorId}	Indicator detail/status change (ETag/If-Match). [v0.1.2 · CR-I4-02]
GET/POST	/typology-matches	Case typology worksheets. [v0.1.2 · CR-I4-03]
GET/ PATCH	/typology-matches/{matchId}	Worksheet detail/update. [v0.1.2 · CR-I4-03]
POST	/typology-matches/evaluate	Preview the computed ceiling and rule trace without recording. [v0.1.2 · CR-I4-03]
GET/POST	/hypotheses	Competing hypotheses.
GET/ PATCH	/hypotheses/{id}	Detail; version-aware update.
GET/POST	/hypotheses/{hypothesisId}/links	Append-only matrix cell versions (target_ref, effect, rationale; If-Match on the hypothesis). [v0.1.2 · CR-I4-04]
GET	/hypothesis-matrix	ACH matrix of a case (case_id required). [v0.1.2 · CR-I4-04]
GET/POST	/intelligence-gaps	Explicit unknowns. [v0.1.2 · CR-I4-05]
GET/ PATCH	/intelligence-gaps/{gapId}	Gap detail/update; never deleted; closed statuses need closure_rationale; status_history. [v0.1.2 · CR-I4-05]
GET/POST	/assessments	Draft/versioned assessments.
POST	/assessments/{id}/finalize	Controlled finalization action.
GET	/assessments/{assessmentId}/revisions	Append-only snapshot per record_version (SRS-FR-ASM-001 version history). [v0.1.2 · CR-I4-05]
GET	/indicators/{indicatorId}/provenance · /typology-matches/{matchId}/provenance · /hypotheses/{hypothesisId}/provenance	Provenance traces. [v0.1.2 · CR-I4-05]

Method	Endpoint	Purpose
POST	/assessments/{assessmentId}/disconfirming-searches	Append an entry to Assessment.disconfirming_searches[] (Data Model §13.3; SRS-FR-ASM-004): searched_for, sources_consulted[] (each source_ref and/or description), result, rationale; recorded_by/recorded_at are server-set. If-Match carries the assessment record_version (missing → 428, stale → 412); returns 201. [v0.1.1 · C10] Allowed on DRAFT and FINALIZED assessments until the assessment (or a product depending on it) passes review approval; afterwards → 409 STATE_CONFLICT. source_ref may name a Source, EvidenceItem or EvidenceExtract of the case (response adds source_type). [v0.1.2 · CR-I4-10]
GET	/assessments/{id}/provenance	Backward trace to hypotheses/facts/evidence: refs per kind (hypothesis_refs, fact_refs, indicator_refs, evidence_refs, typology_match_refs, source_refs, gap_refs) plus the full trace (root, nodes, edges, source_paths). [v0.1.2 · CR-I4-14]

Confidence semantics [v0.1.1 · A09]

confidence.level takes one of HIGH, MODERATE, LOW, INSUFFICIENT_BASIS; confidence.basis (Data Model §14.1) is mandatory for every level. INSUFFICIENT_BASIS means a judgement was attempted but the evidential basis is insufficient; it is not a level below LOW, and the API SHALL NOT convert it to LOW, null, zero, or omit it, in any request, response, filter, sort or export. null is allowed only on drafts where no confidence judgement has been made yet; POST /assessments/{id}/finalize SHALL reject a null level (422). No normalization may raise certainty.

Concern	Rule
Indicators	A catalogue indicator names catalogue_indicator_id (+ catalogue_version) and takes code and class from the catalogue (a contradicting class → 422); a local indicator uses a LOCAL-... code and an explicit class. Evidence: EvidenceExtract, EvidenceItem or Fact (≥1); subjects: Entity, Asset, Event, ValueFlow or Relationship (≥1). indicator_status transitions: OBSERVED → CORROBORATED/DISPUTED/RETIRED; DISPUTED → OBSERVED/CORROBORATED/RETIRED; RETIRED is terminal; every change needs a rationale; never deleted; responses carry is_proof: false. [v0.1.2 · CR-I4-02]
Typology matches	The analyst assigns consistency_level; the server computes computed_ceiling with a rule_trace and rejects a level above it (422); it never raises a level. Matches record indicator_assessments[], direct_authoritative_evidence and direct_evidence_refs; STRONG/COMPELLING set reviewer_required; a cited indicator becoming DISPUTED/RETIRED flags the match review_required. The ceiling thresholds (Typology Catalogue §4) are adopted provisionally and require AML-specialist review. [v0.1.2 · CR-I4-03]
Hypothesis matrix	Each cell (HypothesisLink) stores effect (SUPPORTS, CONTRADICTS, NEUTRAL, UNKNOWN; registry hypothesis_link_effect) with rationale and history. supporting_refs/contradicting_refs are derived from the current cells; writing them creates cells (rationale_supplied: false unless link_rationale is given) and a removed ref becomes NEUTRAL. [v0.1.2 · CR-I4-04, CR-I4-07]
Hypothesis fields	role (PRINCIPAL, ALTERNATIVE_LEGITIMATE, ALTERNATIVE_MECHANISM, INSUFFICIENT_INFORMATION; Methodology §18.1) and assumptions[]; derived competing_hypothesis_refs and status_history. A status change needs status_rationale; SUPPORTED needs a SUPPORTS cell, WEAKENED/REJECTED a CONTRADICTS cell (409). [v0.1.2 · CR-I4-06, CR-I4-08]
Finalization	finalize → 409 STATE_CONFLICT with details.reason = COMPETING_HYPOTHESES_REQUIRED (+ details.hypothesis_refs) when a hypothesis in scope_refs has no competing hypothesis [v0.1.2 · CR-I4-08], and with details.reason = REVIEW_REQUIRED when the draft is flagged review_required [v0.1.2 · CR-I4-11].
Lifecycle	Finalized and reviewed are distinct. Finalize sets finalized, finalized_at, finalized_by, finalization_rationale and envelope status DRAFT → FINALIZED, and freezes the content; review_status stays DRAFT until a review records PEER_REVIEWED/APPROVED/SUPERSEDED, after which the envelope status follows review_status. [v0.1.2 · CR-I4-09]
Disconfirming searches	May be appended to a finalized assessment until review approval; afterwards they are frozen (409). SRS-FR-ASM-004 is checked at review approval (POST /reviews/{reviewId}/approve, 409 DISCONFIRMATION_REQUIRED); responses show disconfirmation_required_for_review. [v0.1.2 · CR-I4-10]

Concern	Rule
Dependent flagging	Direct (supporting_refs) and indirect dependents (the evidence of a supporting Indicator, the indicators of a supporting TypologyMatch, the SUPPORTS cells of a supporting Hypothesis) are flagged review_required, drafts and finalized alike; clearing the flag is a review action. GET /facts/{factId}/dependents lists only dependents the caller may read. [v0.1.2 · CR-I4-11]
Reference targets	scope_refs: Hypothesis, TypologyMatch, Indicator, Entity, Asset, Event, ValueFlow, Relationship. supporting_refs: Fact, Indicator, TypologyMatch, Hypothesis, EvidenceExtract, EvidenceItem (a Source → 422). [v0.1.2 · CR-I4-14]
Case links	Hypotheses, assessments, indicators, matches and gaps require case_links (1..20) and reference only objects inside the case context (§6). [v0.1.2 · CR-I4-12]

16A. Claim and Fact API

[v0.1.1 · A10] — Approved by product owner, 2026-10-08. Resource semantics follow Data Model §7.4 (Claim) and §7.5 (Fact). The paths follow this document's existing style for workflow decisions (/resource/{id}/action sub-paths, as in /assessments/{id}/finalize).

Method	Endpoint	Purpose
GET/POST	/cases/{caseId}/claims	List/record source claims for a case (attributed to a source and/or evidence extract).
GET/ PATCH	/claims/{claimId}	Claim detail; version-aware update of descriptive and handling metadata only (e.g. credibility_grade). claim_status is read-only here and changes only through a VerificationDecision. The asserted proposition is never overwritten by analyst conclusions. [v0.1.1 · A10]
POST	/claims/{claimId}/ verification-decisions	Record an append-only VerificationDecision on a claim. Accepts claim decision values only (UNDER_REVIEW, CORROBORATED, CONTRADICTED, UNRESOLVED); fact decisions are created by the fact commands below. If - Match on the claim is REQUIRED. [v0.1.1 · C01] [v0.1.1 · C18]
GET	/facts/{factId}/provenance	Provenance trace of a fact. [v0.1.2 · CR-I2-04]
GET/POST	/cases/{caseId}/facts	List facts; create a new fact supported by evidence (mandatory) and, optionally, claims, created as PROVISIONAL together with its CREATE VerificationDecision in one transaction. Supporting claims are not modified. [v0.1.1 · A10] [v0.1.1 · C01] [v0.1.1 · C02]
GET	/facts/{factId}	Fact detail, including verification history and superseded_by.
POST	/facts/{factId}/establish	Move a fact to ESTABLISHED (reviewer decision); atomically records the ESTABLISH VerificationDecision (rationale and evidence refs in the body). [v0.1.1 · C01]
POST	/facts/{factId}/dispute	Move a fact to DISPUTED with evidence; atomically records the DISPUTE VerificationDecision (rationale and evidence refs in the body). [v0.1.1 · C01]
POST	/facts/{factId}/supersede	Move a fact to SUPERSEDED with a replacement fact reference; atomically records the SUPERSEDE VerificationDecision (rationale and evidence refs in the body). [v0.1.1 · C01]
GET	/facts/{factId}/dependents	Assessments and intelligence products that depend on the fact, with their review_required state.

Concern	Rule
Claim status	claim_status: RECORDED, UNDER_REVIEW, CORROBORATED, CONTRADICTED, UNRESOLVED. The disputed boolean is kept for compatibility and is derived (status CONTRADICTED or an open dispute); it is read-only. Transitions: RECORDED → UNDER_REVIEW → CORROBORATED/CONTRADICTED/UNRESOLVED; a decided claim may return to UNDER_REVIEW (history kept); any other transition → 409. credibility_grade is "1"..."6" or null (registry credibility_grade). [v0.1.2 · CR-I2-11, CR-I2-08]

Concern	Rule
VerificationDecision	Fields: target_ref (claim or fact), decision (claims: UNDER_REVIEW, CORROBORATED, CONTRADICTED, UNRESOLVED; facts: CREATE, ESTABLISH, DISPUTE, SUPERSEDE — Data Model §7.6) [v0.1.1 · A10], rationale, evidence_refs (EvidenceExtract or EvidenceItem, readable and in the case context; also for Fact.supporting_evidence [v0.1.2 · CR-I2-07]), decided_by (server-resolved principal), decided_at, review_ref (optional). Append-only: no PATCH/DELETE; corrections are new decisions.
Fact creation	POST /cases/{caseId}/facts SHALL include supporting_evidence (1..n, mandatory) and decision_rationale (required); supporting_claim_refs (0..n) and review_ref are optional. Missing supporting_evidence or decision_rationale → 422. The server creates the fact and its CREATE VerificationDecision (target = the new fact, evidence_refs = supporting_evidence) atomically in one transaction. verification_decision_refs is server-populated and read-only: it is not accepted in the request and the response returns it containing the new decision. The new fact starts as PROVISIONAL. A claim is never converted into a fact. [v0.1.1 · A10] [v0.1.1 · C01] [v0.1.1 · C02]
Fact status	fact_status: PROVISIONAL, ESTABLISHED, DISPUTED, SUPERSEDED; superseded_by references the replacement fact.
Permissions	Investigator/Analyst MAY record claims and propose PROVISIONAL facts. establish requires a Reviewer who is not the proposer (otherwise 403). Any authorized case member MAY dispute with evidence refs. supersede requires a replacement fact ref (otherwise 422). Role mapping: establish requires REVIEWER or LEAD membership on the fact's case and is never allowed to the proposer (403); claim decisions are recorded by LEAD, ANALYST or REVIEWER members; dispute by any member role; supersede needs case.update. [v0.1.2 · CR-I2-11]
Preconditions	PATCH /claims/{claimId}, POST /claims/{claimId}/verification-decisions (If-Match on the claim) and every fact command SHALL send If-Match (§10): missing → 428, stale → 412. [v0.1.1 · C18] An invalid transition (e.g. establishing a SUPERSEDED fact) → 409 STATE_CONFLICT. Commands SHOULD send Idempotency-Key (§11).
Dependent impact	When a fact becomes DISPUTED or SUPERSEDED, every dependent Assessment and IntelligenceProduct is flagged review_required with a link to the triggering decision. Published products are never mutated; a correction review task is created. History is preserved.
Certainty	A claim SHALL NOT be returned or exported as a fact without a VerificationDecision.
Audit	Claim creation, every VerificationDecision and every fact status change emit audit events (§27).

17. Search API

| GET /api/v1/search?q=company+x&type=entity,evidence&case_id=...&status=...&page[size]=25

Response element	Rule
results	Only authorized canonical/derived references.
snippet	Permission-safe; SHALL not reveal hidden protected content.
facets	Permission-filtered counts.
rank/score	Search relevance only; SHALL not be labeled risk/suspicion.
source	Canonical object type + stable ID.
projection marker	Derived/extracted text result identifies derivative source when applicable.

Adopted for v0.1.3 [v0.1.3 · CR-I5-01] The search operation is GET /api/v1/search (search0bjects) in contracts/openapi.yaml. Search results are a derived, rebuildable

projection over canonical records (API-P07); every hit is a pointer to the canonical object, not a copy.

Element	Rule (v0.1.3)
Parameters	q (≤ 200 characters, ≤ 12 word tokens, each matched as a prefix with accents and case folded; names, aliases and identifiers also match by trigram similarity), type (registry search_object_type), case_id, classification, status, entity_type, flow_class (a value flow's own class or any leg's class), date_from / date_to (the object's domain date), include_source_protected, facets, sort (relevance, updated_at, created_at, title; - prefix for descending; default relevance with q, updated_at without), cursor page (default 25, maximum 100). <i>[v0.1.3 · CR-I5-01]</i>
Hit	object_type (registry search_object_type: CASE, ENTITY, SOURCE, EVIDENCE_ITEM, EVIDENCE_EXTRACT, CLAIM, FACT, RELATIONSHIP, ASSET, EVENT, VALUE_FLOW, PRODUCT), canonical_type, title, snippet as plain-text segments {text, match} (never HTML), classification, status, epistemic_status (registry search_epistemic_status: CLAIM, FACT, EXCERPT, RECORD, and since v0.1.4 DERIVED — a claim is never shown as a fact), derived_from (projection marker), case_context (readable cases only), relevance (text match only; SHALL NOT be labelled risk or suspicion), links.self (canonical API resource) and links.ui (SPA route). <i>[v0.1.3 · CR-I5-01, CR-I5-03]</i>
Facets	object_type, classification, status, entity_type, flow_class, case; computed on the authorized, filtered set only. <i>[v0.1.3 · CR-I5-01]</i>
Authorization	Applied in the query before results, total_count, facets, snippets and ordering; page rows are re-checked against the canonical objects (fail closed). Relevance is a per-document score without corpus statistics, so hidden objects never influence ordering. <i>[v0.1.3 · CR-I5-01]</i>
SOURCE_PROTECTED	Excluded by default, including ordinary objects whose only readable context is a SOURCE_PROTECTED case. Returned only with include_source_protected=true and the per-case protected-source grant (IdP eligibility role plus protected_source_authorized membership); without the grant the flag changes nothing — no hit, count, facet or snippet. Protected-source <i>identity</i> stays outside generic search (§21). <i>[v0.1.3 · CR-I5-04]</i>
Index scope	Cases; entities (names, aliases, identifiers); sources; evidence metadata ; extracts (cited text); claims; facts; relationships (type and dates only — never endpoint names, which may be unreadable); assets; events; value flows; products. Evidence file content (OCR / full text) is not indexed (Phase 2); hypotheses, assessments and indicators are not indexed in MVP 0.1. An extract hit links to GET /evidence-extracts/{extractId}. <i>[v0.1.3 · CR-I5-07]</i>
Limits	120 requests per minute per user (429 RATE_LIMITED); statement timeout 5 s (503). See §25 for the timing channel. <i>[v0.1.3 · CR-I5-08]</i>
Performance	SRS-NFR-PERF-002 (global search, first page ≤ 3 s) and the case-scoped target (p95 < 2 s) both apply, measured on the synthetic reference corpus (SRS-NFR-PERF-004). <i>[v0.1.3 · CR-I5-09]</i>
Derived text (amends CR-I5-07)	Completed DerivedText (OCR, extraction, translation) is indexed as object type DERIVED_TEXT with the epistemic marker DERIVED ("machine-derived text, not the original evidence"); status is its review state; the hit links back to the derived text and the original page. Policy-filtered like every row, never indexed before completion; a deployment switch (CSAML_DERIVED_TEXT_SEARCH=false) removes it. The original evidence file content itself is still not indexed. <i>[v0.1.4 · CR-N-11]</i>

18. Graph API

Adopted for v0.1.2 *[v0.1.2 · CR-I3-07]*

The adopted graph operation is the per-case projection GET /api/v1/cases/{caseId}/graph (filters include, flow_class, relationship_type): policy-filtered nodes (Entity, Asset, Event) and edges (Relationship incl. ownership/control details, ValueFlow, ValueFlowLeg with its own class, event participation) with confidence, status and readable provenance refs; computed on demand and marked meta.derived; budgets apply. POST /graph/query below was left open in v0.1.2; v0.1.3 specifies it (next block).

```
POST /api/v1/graph/query
{
  "case_id": "...",
  "seed_entities": [...],
  "relationship_types": ["OWNS", "DIRECTOR_OF"],
  "depth": 2,
  "include_value_flows": true
}
```

Element	Requirement
Nodes	Canonical object references with authorized display metadata.
Edges	Relationship/ValueFlow IDs, type, dates, confidence/status, provenance refs as authorized.
Derived metrics	Explicitly marked derived with algorithm/version/input scope.
Path query	Output means path in authorized graph, not proof of culpability/causality.
Limits	Server enforces depth/node/edge budgets and rate limits.
Rebuildability	Graph projection is never the sole canonical source.

Adopted for v0.1.3 [v0.1.3 · CR-I5-02] POST /graph/query (queryGraph) and POST /graph/paths (findGraphPaths) are specified in contracts/openapi.yaml. Nodes and edges reuse the shapes of the per-case projection (GraphNode, GraphEdge).

Element	Rule (v0.1.3)
Query	The sketch fields above plus seed_assets, flow_classes, include_events, include_relationships, include_leads, and lower max_nodes / max_edges. Undirected breadth-first expansion over readable Relationships, ValueFlows / ValueFlowLegs (each with its own flow class) and Event participation. Nodes add depth, seed, lead_only and case_refs (readable cases only). [v0.1.3 · CR-I5-02]
Paths	from, to, max_depth (default 3), max_paths (default 5, maximum 10); shortest paths over the same authorized expansion. A path is not proof of control, causality or wrongdoing. [v0.1.3 · CR-I5-02]
Scope	With case_id the walk stays inside that case; without it, it crosses into other cases only where the caller may read the objects. [v0.1.3 · CR-I5-02]
Budgets	Depth default 2, cap 3 (422 above); 500 nodes; 1,500 edges; 4 s wall clock. A request may only lower the caps. [v0.1.3 · CR-I5-02]
Partial results	A node, edge, time or lead budget returns a partial result with meta.truncated = true and meta.truncation_reasons (registry graph_truncation_reason: NODE_BUDGET, EDGE_BUDGET, TIME_BUDGET, LEAD_BUDGET); the client shows the reasons. Only the statement-timeout backstop (5 s) is an error: 503 with details.reason = "QUERY_TIME_BUDGET". [v0.1.3 · CR-I5-06]
Errors	An unreadable seed or path endpoint → non-disclosing 404 (audited); a readable seed outside case_id → 422. [v0.1.3 · CR-I5-02]
Leads	With include_leads, readable entities in scope that record the same normalized value are returned as leads (registry graph_lead_type): SHARED_IDENTIFIER (same identifier type and value), SHARED_PHONE, SHARED_EMAIL, SHARED_ADDRESS. Normalization: values are case-folded, accent-stripped and reduced to letters and digits; phone numbers to digits only; values shorter than 4 characters are ignored; ADDRESS / PHONE / EMAIL entities whose name is the value count. Every lead is confirmed against the canonical identifiers. A lead has status: CANDIDATE, is_fact: false, merge_performed: false; it is never an edge, never stored, and nothing is written. An analyst who confirms one records a relationship (e.g. SHARES_PHONE_WITH) or a resolution decision as usual. [v0.1.3 · CR-I5-05]
Limits	60 requests per minute per user for query and paths together (429 RATE_LIMITED). [v0.1.3 · CR-I5-08]

19. Product, Review and Dissemination API

Method	Endpoint	Purpose
GET/POST	/products	Intelligence product library/create.
GET/ PATCH	/products/{productId}	Current draft/version-aware edit.
GET	/products/{productId}/ versions	Version history.
POST	/products/{productId}/ submit-review	Freeze/submit version.
GET	/reviews	Review queue.
GET	/reviews/{reviewId}	Review workspace data.
POST	/reviews/{reviewId}/ request-changes	Decision action.
POST	/reviews/{reviewId}/ approve	Independent approval. Approving a review whose target is, or depends on, a high-impact or adverse assessment with no <code>disconfirming_searches</code> entry → 409 STATE_CONFLICT with <code>details.reason = "DISCONFIRMATION_REQUIRED"</code> (SRS-FR-ASM-004; enforced at review approval, not at finalization). <i>[v0.1.1 · C10]</i>
POST	/reviews/{reviewId}/reject	Reject with rationale.
POST	/disseminations	Create dissemination request.
POST	/disseminations/{id}/ approve	Authorize recipient/purpose/package scope.
GET	/disseminations/{id}/ export-candidates	Authorized selectable export objects.
POST	/disseminations/{id}/ exports	Generate export package.
GET	/sharing-log	Immutable authorized sharing records.
GET	/product-templates	The six MVP templates with typed sections and bindings. <i>[v0.1.3 · CR-I6-01]</i>
GET	/products/{productId}/ rendering	Live rendering of the working version from readable canonical objects. <i>[v0.1.3 · CR-I6-01]</i>
GET	/products/{productId}/ versions/{version}	One frozen version with its document and <code>content_sha256</code> . <i>[v0.1.3 · CR-I6-01]</i>
POST	/products/{productId}/ corrections	Open a correction version. <i>[v0.1.3 · CR-I6-05]</i>
POST	/products/{productId}/ withdraw	Withdraw a product (case LEAD). <i>[v0.1.3 · CR-I6-05]</i>
POST	/assessments/ {assessmentId}/ submit-review	Submit a finalized assessment for review. <i>[v0.1.3 · CR-I6-02]</i>
POST	/review-requests	Request a REVIEW_FLAG_CLEARANCE or HANDLING_CHANGE review. <i>[v0.1.3 · CR-I6-02, CR-I6-12]</i>
GET	/disseminations	Dissemination requests and approvals. <i>[v0.1.3 · CR-I6-06]</i>
POST	/disseminations/{id}/revoke	Revoke a dissemination (requester or an approver). <i>[v0.1.3 · CR-I6-06]</i>
GET	/export-packages, / export-packages/{exportId}	Export packages with manifest, hashes and approval validity. <i>[v0.1.3 · CR-I6-08]</i>
GET	/export-packages/ {exportId}/content	Download; re-checks authorization and approval validity (409 when invalid). <i>[v0.1.3 · CR-I6-08]</i>

Concern	Rule (v0.1.3)
Templates and document	Six templates with typed sections (SUBJECTS, FACTS, CLAIMS, ANALYSIS, UNKNOWN, CONTEXT) and bindings. Products add <code>subject_refs</code> (Entity, Asset) and <code>contact_point</code> ; template requirements → 422. The product document (<code>csaml.product-document/1</code>) keeps each item's epistemic kind and carries an evidence index (facts → decisions, claims, extracts with locators → evidence → sources). / rendering is live; /versions/{version} is frozen with <code>content_sha256</code> . Responses add author, contributors, reviewers, reviews, frozen_version, approved_version, editable. <i>[v0.1.3 · CR-I6-01]</i>
Review kinds	<code>review_kind</code> (registry): PRODUCT_VERSION, ASSESSMENT, REVIEW_FLAG_CLEARANCE, HANDLING_CHANGE, CORRECTION — all decided through <code>approve</code> / <code>request-changes</code> / <code>reject</code> . Authors, contributors and the requester can never decide (403, also a database trigger); deciding needs a REVIEWER or LEAD membership. <i>[v0.1.3 · CR-I6-02]</i>

Concern	Rule (v0.1.3)
Review / version lifecycle	Review status (registry review_status): OPEN → DECIDED / CANCELLED. Frozen version status (registry product_version_status): SUBMITTED → APPROVED / APPROVED_WITH_CHANGES / RETURNED / REJECTED → SUPERSEDED / RETRACTED. APPROVE → product APPROVED; APPROVE_WITH_CHANGES → product REVIEWED (not disseminable: the change needs a new version and review); RETURN / REJECT → product DRAFT. The first edit after a frozen version opens version n+1. Assessment reviews: APPROVE → APPROVED, APPROVE_WITH_CHANGES → PEER_REVIEWED. [v0.1.3 · CR-I6-03]
review_required	Reasons (registry review_reason): FACT_DISPUTED, FACT_SUPERSEDED, INPUT_HANDLING_UPGRADED. Approval → 409 REVIEW_REQUIRED while an assessment in scope is flagged, or while the product is flagged unless the reviewer sets clear_review_required (recorded as cleared_review_required). A REVIEW_FLAG_CLEARANCE review clears an assessment or product. A DISSEMINATED product is never mutated: an OPEN CORRECTION review is created and new disseminations are blocked (409 CORRECTION_REVIEW_OPEN). [v0.1.3 · CR-I6-04]
Corrections and withdrawal	A correction turns an APPROVED / REVIEWED / DISSEMINATED product into DRAFT version n+1 with correction_note; earlier versions stay valid until the correction is approved, then become SUPERSEDED together with their disseminations. Withdrawal (case LEAD): versions RETRACTED, open reviews CANCELLED, disseminations REVOKED. [v0.1.3 · CR-I6-05]
Dissemination	handling_classification (at least the product's, 422 otherwise); status (registry dissemination_status): REQUESTED → APPROVED / REVOKED → SUPERSEDED; an approved release is immutable. Approver: a REVIEWER or LEAD member (DISSEMINATION_APPROVE), never the requester (403). Approval marks the product DISSEMINATED and writes the sharing log. [v0.1.3 · CR-I6-06]
Source-protected release	Objects classified SOURCE_PROTECTED (including a source-protected product) are inside an approved scope only with source_protected_release set by an approver holding the per-case protected-source grant, with a rationale (403 / 422 otherwise). Without it, packages withhold every source-protected item, index entry and citation; the count is recorded in redactions, the content never. [v0.1.3 · CR-I6-07]
Export packages	Format (registry export_package_format): CSAML_PACKAGE_ZIP_V1 — a deterministic ZIP with README, product/document.json and .html, objects/*.json, evidence originals and manifest.json with the SHA-256 of every file. Status (registry export_package_status): QUEUED → GENERATING → READY / FAILED. Fields files, package_sha256, manifest_sha256, redactions, approval_valid. The download answers 409 when the approval was revoked or superseded, the version superseded or retracted, or the product withdrawn. Sharing-log entries add entry_type (registry sharing_log_entry_type: RELEASE_APPROVED, EXPORT_GENERATED, RELEASE_REVOKED), product_version, handling_caveats, handling_classification. [v0.1.3 · CR-I6-08]
Export generation	POST /disseminations/{id}/exports always answers 202 JobAccepted (with Location: /api/v1/jobs/{id} and the QUEUED export_package); a retry with the same Idempotency-Key replays the same job. Export candidates are computed from the frozen version and returned as one page (next_cursor: null) with source_protected and in_approved_scope; single-page derived lists are allowed. [v0.1.3 · CR-I6-11]
Handling changes	Every classification / access-label change of a canonical object is an append-only HandlingChange (Data Model §16.4): UPGRADE applied directly, DOWNGRADE only with its approved HANDLING_CHANGE review. A product keeps handling_decision_ref. review_trigger_ref of a flagged assessment or product names a VerificationDecision or a HandlingChange. [v0.1.3 · CR-I6-12]

20. Administration and Audit API

Method	Endpoint	Purpose
GET/POST	/vocabularies	Controlled vocabulary management.
GET/POST	/retention-policies	Retention policy management. Specified in v0.1.3 as /retention-rules (§20A). [v0.1.3 · CR-I7-01]

Method	Endpoint	Purpose
GET/POST · PATCH/ DELETE	/cases/{caseId}/ memberships · / case-memberships/ {membershipId}	Case membership/access administration (§12; If-Match on PATCH/DELETE; managed by the case LEAD). [v0.1.2 · CR-I1-02]
GET	/audit-events	Permission-aware immutable audit explorer.
GET	/system/info	Build/schema/API version and safe diagnostics.
GET	/system/health	Health check; public/private detail according to deployment. Specified in v0.1.3 as GET /health (getHealth): unauthenticated readiness probe reporting status and latency of the database, Valkey and the object store, plus build version, commit and schema version — never case content, hostnames or credentials; a failed dependency → 503 DEPENDENCY_UNAVAILABLE. The Prometheus endpoint /metrics is internal (scraped inside the deployment network, never routed by the reverse proxy) and is not part of the API. [v0.1.3 · CR-I7-08]
GET	/capabilities	Optional principal/deployment capability summary.

20A. Retention, Legal Hold and Disposition API [v0.1.3 · CR-I7-01]

Method	Endpoint	Purpose
GET/POST	/retention-rules	Retention rules (Data Model §16.1); platform administrators.
GET/ PATCH	/retention-rules/{ruleId}	Rule detail; versioned update (If-Match, change_reason). applies_to never changes; RETIRED is final.
POST	/retention-evaluations	Evaluate rules: REPORT (counts only) or PROPOSE (opens disposition records). Nothing executes. Also scheduled daily in REPORT mode.
GET/POST	/legal-holds	Legal holds (Data Model §16.2); placed by an administrator or the case LEAD.
GET	/legal-holds/{holdId}	Hold detail.
POST	/legal-holds/{holdId}/release	Release a hold, once, with a reason. Idempotency-Key REQUIRED.
GET	/disposition-records, / disposition-records/{recordId}	The disposition log (Data Model §16.3).
POST	/disposition-records/ {recordId}/approve, .../reject	Decision by the LEAD of every case the target is linked to, never the proposer (403). Refused under an active legal hold (409). Idempotency-Key REQUIRED.
POST	/disposition-records/ {recordId}/execute	Execute an approved disposition (administrator or approver).

Concern	Rule
Targets	applies_to / target_type (registry retention_target_type): EVIDENCE_ITEM, EXPORT_PACKAGE, CASE; a rule MAY be narrowed by applies_to_classifications. A legal hold on a case covers every object linked to it. [v0.1.3 · CR-I7-02]
Statuses	Rule rule_status (registry retention_rule_status): ACTIVE, RETIRED. Hold hold_status (registry legal_hold_status): ACTIVE, RELEASED. Disposition disposition_status (registry disposition_status): PROPOSED → APPROVED / REJECTED → EXECUTING → EXECUTED. [v0.1.3 · CR-I7-03, CR-I7-04]
Evaluation	Several matching rules: the most protective governs (eligible only when all have expired; the latest date wins). The trigger CASE_CLOSURE uses Case.closed_at. [v0.1.3 · CR-I7-01, CR-I7-06]
Supported dispositions (MVP 0.1)	DELETE purges the stored bytes (every object version) of an evidence original or export package and keeps the row (hash, size, storage reference) as the tombstone; ARCHIVE and REVIEW record the retention state. Rows and audit events are never deleted. ANONYMIZE and whole-case DELETE are refused (422) and deferred to v0.2 (they need a reviewed anonymiser and a case-level tombstone design). [v0.1.3 · CR-I7-05]
Execution	execute re-checks the rule and legal holds (409; the database refuses it too) and commits in two steps (EXECUTING, then EXECUTED) so purged bytes are never without a record; a failed purge stays EXECUTING (503) and may be retried. It is not under the Idempotency-Key ledger: the state machine makes a repeat harmless (409). Disposed evidence content answers 409 (§13). [v0.1.3 · CR-I7-01, CR-I7-07]

Concern	Rule
Visibility	Records about a target carry its classification, labels and case links, so they are visible exactly where the target is; administrators see references only. [v0.1.3 · CR-17-04]

21. Protected Source API Boundary

- Protected-source identity SHALL use dedicated endpoints and authorization scopes separated from ordinary source/evidence APIs.
- Ordinary evidence/source payloads SHALL reference protected source through non-identifying handles where needed.
- Protected-source identity SHALL not be included in generic search, graph, audit payloads, export candidates or global capability summaries.
- API documentation/examples SHALL use synthetic values and SHALL not encourage clients to cache protected identity broadly.

| /api/v1/protected-sources/... # restricted namespace; not part of ordinary analyst client bundle by default

22. Asynchronous Jobs

Operation	Async?	Pattern
Large evidence processing	YES	Return 202 + job resource.
OCR/derivative generation	YES (since v0.1.4)	202 + job (job_type TEXT_EXTRACTION / MACHINE_TRANSLATION) + DerivedText on completion (§13). [v0.1.4 · CR-N-09, CR-N-12]
Large export package	YES	202 + job; final download only after approval remains valid.
Graph projection rebuild	YES	Admin/operator job.
Normal CRUD	NO	Synchronous transaction.
Search	NO	Synchronous with timeout/rate limits.

| 202 Accepted
 { "job": { "id": "job_...", "status": "QUEUED", "poll_url": "/api/v1/jobs/job_..." } }

Job status (registry job_status): QUEUED → RUNNING → SUCCEEDED / FAILED. Jobs add job_type, target_type, target_ref and result_url; a job is readable by whoever may read its target. Export package generation is always asynchronous (202, §19). [v0.1.3 · CR-16-09, CR-16-11]

Job type (registry job_type): EXPORT_PACKAGE (target ExportPackage), TEXT_EXTRACTION and MACHINE_TRANSLATION (target DerivedText; result_url = the derived text; error is a safe code only). [v0.1.4 · CR-N-12]

23. File Transfer and Content Safety

- Uploads SHALL enforce server-side size/type policy and SHALL not trust browser MIME/extension alone.
- Original filenames are metadata; object storage keys are opaque.
- Content downloads SHALL use safe Content-Type/Content-Disposition and authorization on every request.
- Range requests MAY be supported for large evidence viewing.
- Active documents SHOULD be served in a way that prevents execution in the CS-AML origin context.
- Malware scanning/quarantine hooks SHALL not silently rewrite the original evidence; quarantine state is metadata/workflow.

24. Bulk Operations

Bulk action	MVP
Bulk tag/classify low-risk metadata	MAY support with per-object authorization/results.
Bulk evidence export	Only through approved dissemination/export workflow.
Bulk entity merge	NOT supported.
Bulk deletion	NOT supported for ordinary analyst.
Bulk relationship import	MAY be later; each record requires provenance/validation.
Bulk audit retrieval	Privileged, paginated/rate-limited.

25. Rate Limiting and Abuse Controls

- Authentication, search, graph traversal, export generation and upload endpoints SHOULD have differentiated limits.
- Rate-limit responses use 429 and MAY include Retry-After.
- Limits SHALL not reveal hidden resource counts.
- Privileged/bulk APIs require stronger authorization and audit.
- Automated clients/service accounts SHOULD have separately identifiable quotas.
- MVP 0.1 limits: search 120 requests per minute per user; graph query and paths 60 per minute per user (429 RATE_LIMITED); search statement timeout 5 s. Hidden objects never influence results, counts, facets or ordering, but query latency still depends on the total corpus size. This residual timing channel is **accepted for MVP 0.1 with synthetic data only** and SHALL be re-reviewed (and mitigated or re-accepted by the accountable authority) before real, non-synthetic data is processed. [v0.1.3 · CR-I5-08]

26. API Security Requirements

ID	Requirement
API-SEC-01	TLS required outside explicitly isolated local development. Local-development exception: only an explicitly isolated local-development settings profile MAY rename the session cookie and drop Secure for plain-http localhost; production settings always enforce __Host-csaml_session with Secure. [v0.1.2 · CR-I1-06]
API-SEC-02	All object access is authorized server-side using role + case/context + classification + need-to-know as applicable.
API-SEC-03	Object IDs are not authorization secrets.
API-SEC-04	Mass assignment is prevented by explicit writable-field schemas.
API-SEC-05	Input validation and output encoding are applied consistently.
API-SEC-06	CSRF protection applies to every unsafe method: browser auth is a cookie-based BFF session and requests SHALL carry X-CSRFToken (§4). [v0.1.1 · A11]
API-SEC-07	The API is same-origin; CORS is disabled by default and any exception is explicit and minimal. [v0.1.1 · A11]
API-SEC-08	Sensitive payloads are excluded/redacted from routine access logs.
API-SEC-09	Export/download endpoints re-check authorization at retrieval time where appropriate.
API-SEC-10	Schema/docs do not expose privileged endpoints to unauthorized clients as an access control mechanism; actual authorization still applies.
API-SEC-11	Automation engines (OCR, machine translation and any future AI) run offline on the CS-AML host; evidence content SHALL NOT be sent to a third-party service and there is no online fallback. [v0.1.4 · CR-N-10]
API-SEC-12	High-risk actions require a recent second-factor step-up (§4). [v0.1.4 · CR-N-13]

27. Audit Semantics

Action	Audit expectation
Create/update canonical object	Actor, action, object, version, timestamp, request ID; material before/after reference.
Entity merge/unmerge	Decision/rationale/evidence references + topology-impact record; references the ResolutionDecision. Every ResolutionDecision emits an audit event. <i>[v0.1.1 · ER]</i>
Assessment finalize	Version, author, confidence, gate state.
Case membership	Grant, role/grant change and revocation with actor and principal. <i>[v0.1.2 · CR-I1-02]</i>
Review decision	Reviewer, product/version, decision, rationale.
Dissemination approval/export	Recipient/purpose/package/version/included object manifest.
Failed high-impact action	Security/audit event where policy requires.
Step-up	auth.step_up at a successful step-up callback; auth.step_up_required when a high-risk action is refused for lack of a recent step-up. <i>[v0.1.4 · CR-N-13]</i>
Gate / task / derived text	Gate submit / approve / reject (with charter version and case-status transition), task changes, derived-text request, completion and review. <i>[v0.1.4 · CR-N-03, CR-N-04, CR-N-09]</i>
Read access	Routine reads MAY be logged selectively; protected-source/access-sensitive reads SHOULD have stronger audit policy.

28. API Schema and OpenAPI Requirements

- The OpenAPI 3.1 contract SHALL be maintained contract-first in contracts/openapi.yaml, linted in CI, used to generate the TypeScript client, and exercised by contract tests; the schema generated from the implementation SHALL be diffed against it in CI. *[v0.1.1 · A11]* *[v0.1.1 · C12]*
- Schemas SHALL identify required/nullable fields explicitly.
- Enums SHALL include stable machine values and descriptions.
- Examples SHALL use synthetic data.
- High-impact action endpoints SHALL document preconditions and conflict/error codes.
- Client TypeScript types SHALL be generated from contracts/openapi.yaml; generated code SHALL not replace domain semantics documentation. *[v0.1.1 · A11]*

Contract status — P0 vertical slice *[v0.1.1 · A11]*

contracts/openapi.yaml (OpenAPI 3.1, contract-first) now covers the P0 vertical slice: common envelopes and errors, auth/session, cases, sources/evidence (incl. upload and integrity), claims/facts/verification decisions, entities/relationships incl. merge/unmerge and resolution decisions, value flows, hypotheses/assessments, reviews, intelligence products and dissemination/export. It passes Redocly lint and tools/check_consistency.py (enum values against schemas/enums.yaml). Contract choices the prose left open were classified once on 2026-10-08 with x-csaml-release-class *[v0.1.1 · G5]*: **MUST_DECIDE_V0_1_1** (decided — see below), **ACCEPT_DEFAULT_V0_1_1** (frozen default that may evolve only compatibly) and **DEFER_V0_2**. Accepted defaults include: the cursor pagination envelope {items, page:{size, next_cursor, has_more, total_count?, total_count_is_estimate?}}; 400 INVALID_REQUEST for a missing REQUIRED Idempotency-Key; field_errors as a field → messages map; and read endpoints added so clients can obtain ETags (GET /hypotheses/{id}, /assessments/{id}, /disseminations/{id}, /jobs/{jobId}). The implementation SHALL conform to this contract; once code exists, the schema generated from the implementation SHALL be diffed against it in CI. No implementation or contract test has been run yet. *(v0.1.1 statement;*

since v0.1.2 the reference implementation's increments I1-I4 run contract tests against it — see *CHANGELOG.md*.) [v0.1.2 · CR-I1-01...CR-I4-14]

v0.1.2 scope [v0.1.2 · CR-I1-01...CR-I4-14]

contracts/openapi.yaml v0.1.2 merges the I3 and I4 implementation extensions (contracts/extensions/i3.yaml, i4.yaml of the reference implementation) and the I1/I2 additions into the main contract: 111 paths, 149 operations (v0.1.1: 72 paths, 92 operations). Added: memberships, back-channel logout, provenance traces, assets/ownership interests/control assertions, events/timeline, value-flow view and legend, the case graph, the typology catalogue, indicators, typology matches, the hypothesis matrix, intelligence gaps and assessment revisions. Items decided on 2026-10-09 carry the release class **DECIDED_V0_1_2** (x-csaml-status: decided) and x-csaml-cr with their change-request IDs; x-csaml-ref-types lists the permitted target classes of a reference field. /entity-match-candidates/{id}/decisions is marked deprecated (removal in v0.2). Closed since v0.1.1: upload-session status, risk_rating, amount precision, CSRF-token delivery and the match-candidate overlap.

v0.1.3 scope [v0.1.3 · CR-I5-01...CR-I7-08] contracts/openapi.yaml v0.1.3 merges the I5, I6 and I7 implementation extensions (contracts/extensions/i5.yaml, i6.yaml, i7.yaml of the reference implementation) and adds GET /evidence-extracts/{extractId} and GET /health: 138 paths, 180 operations (v0.1.2: 111 paths, 149 operations). Added: search; graph query and paths; product templates, rendering, frozen versions, corrections and withdrawal; assessment review submission and review requests; dissemination list and revocation; export package list, detail and download; retention rules, evaluations, legal holds and disposition records. Changed: generateExportPackage answers 202 only; getEvidenceContent documents 409 for disposed originals; CaseMembershipList and EvidenceExtractList carry the page under items only (v0.1.2 defect). New items carry the release class **DECIDED_V0_1_3**. Closed since v0.1.2: search, POST /graph/query, job status, export format, retention API, health.

v0.1.4 scope [v0.1.4 · CR-N-01...CR-N-14] contracts/openapi.yaml v0.1.4 merges the post-MVP implementation extensions (contracts/extensions/case-workflow.yaml and n1.yaml of the reference implementation): 146 paths, 190 operations (v0.1.3: 138 paths, 180 operations). Added: charter version history and one version, task detail and update, OCR / text-extraction requests, translation requests, derived-text list, detail and review. Changed: charter, gate, task and activity shapes; ErrorCode adds STEP_UP_REQUIRED and 13 high-risk operations document it (x-csaml-step-up); Session adds auth_level, auth_time, step_up; authLogin takes acr and next; authCallback answers 303 LoginErrorRedirect instead of 400 / 401 / 503; SearchObjectType / SearchEpistemicStatus add DERIVED_TEXT / DERIVED; Job.job_type is the registry job_type. New items carry the release class **DECIDED_V0_1_4**. Closed since v0.1.3: gate and task status, task contracts, derivation_type vocabulary, OCR / derivative generation.

Still outstanding:

- Endpoints outside the contract: administration/audit (other than retention and health), protected sources, GET /capabilities. [v0.1.3 · CR-I5-01, CR-I5-02, CR-I7-01, CR-I7-08]
- Open value sets still typed as plain strings: Asset.valuation_basis vocabulary (free text, required when a valuation is given); Methodology §14.1 event statuses (not registered). [v0.1.2 · CR-I2-02, CR-I1-08, CR-I3-05, CR-I3-06] [v0.1.3 · CR-I6-08, CR-I6-09] Gate and task status are registered since v0.1.4. [v0.1.4 · CR-N-03, CR-N-04]
- Per-resource sort allowlists.
- Task contracts (Task, TaskCreate): decided in v0.1.4 (TaskPatch, getTask, updateTask). [v0.1.4 · CR-N-04]
- Deferred to v0.2: MONITORING and reopening of cases; gate configuration per organisation or risk tier; per-deployment step-up configuration and phishing-resistant factors (WebAuthn / passkeys) for approvers; server-side activity filters (actor, action, target_type) and an auditor view; links from tasks to sources, entities and hypotheses. [v0.1.4 · CR-N-03, CR-N-04, CR-N-06, CR-N-08, CR-N-13]

Decisions for v0.1.1 (MUST_DECIDE_V0_1_1, product owner 2026-10-08) [v0.1.1 · G5]

1. A request without a REQUIRED Idempotency-Key is rejected with 400 INVALID_REQUEST and is not executed.
2. A review approval binds to the frozen product version under review (target_version); any later change creates a new version that needs a new review. The reviewer must not be the author; SRS-FR-ASM-004 is enforced at approval.
3. Dissemination approval fixes recipient, purpose, product version and package_scope_refs. Export packages may contain only objects inside that scope (otherwise 409 STATE_CONFLICT); any change needs a new approval. Downloads re-check authorization and approval validity.
4. reviewer_ref on high-impact merge/unmerge is the reviewing principal (a person); the server rejects reviewer = decider (409 STATE_CONFLICT). Since v0.1.2 every MERGE/UNMERGE is high-impact, so reviewer_ref is always required. [v0.1.2 · CR-12-10]
5. Evidence upload completion is all-or-nothing: metadata, storage write and integrity record succeed together or no EvidenceItem exists; a hash mismatch returns 422.
6. Relationship source, target and type are immutable on PATCH; changes are made by creating a new relationship.
7. POST /evidence/{evidenceId}/verify-integrity takes no If-Match; it never modifies the evidence and its result is recorded as a separate audited event.

29. Compatibility and Deprecation

Change	Policy
Add optional response field	Compatible.
Add enum value	Potentially compatible only if clients are required to handle unknown values safely; announce.
Rename/remove field	Breaking; new major or migration window.
Change meaning of existing field	Breaking even if JSON shape unchanged.
Endpoint deprecation	Mark in schema/docs, announce removal version/date, provide replacement.
Controlled vocabulary change	Vocabulary versioning; historical records retain original term semantics.

30. Verification and Contract Testing

Test class	Required verification
Schema	Responses validate against OpenAPI/schema.
Authorization	Positive and negative tests for case membership/classification/protected source.
Non-disclosure	Unauthorized IDs/search/facets do not reveal hidden resource metadata.
Concurrency	Stale If-Match → 412 PRECONDITION_FAILED; missing If-Match → 428; workflow conflict → 409 STATE_CONFLICT; no overwrite in any case. [v0.1.1 · A04] Multi-entity commands use expected_versions (§10): missing → 428, mismatch → 412 with details.current_record_versions. [v0.1.1 · C03]
Idempotency	Retries do not duplicate selected actions; replay, key-reuse (422) and in-flight (409) behaviour per §11. [v0.1.1 · A11]
Evidence	Upload/finalize/hash/content authorization and lineage.
Analytical semantics	Flow classes, unknown/range values, candidate/disputed states preserved; INSUFFICIENT_BASIS round-trips unchanged; claim/fact transitions per §16A. [v0.1.1 · A09, A10]

Test class	Required verification
Review/ dissemination	Independent approval/preconditions/export manifest enforced.
Audit	Material actions create expected correlated audit records.
Performance	P0 list/search/graph endpoints meet documented MVP targets.

31. API Definition of Done

Area	Done when
Contract	Endpoint/resource has documented schema, methods, authorization context and error cases.
Traceability	Mapped to feature/SRS requirement.
Authorization	Positive/negative/non-disclosing tests pass.
Versioning	Mutable material resource has conflict semantics.
Audit	Material action emits required audit event/correlation.
Frontend	Generated/manual client integration handles loading/error/conflict states.
Docs	OpenAPI/examples updated with synthetic data.
Security	Input/output/file/download controls pass review.
Regression	Contract tests included in CI.

Annex A — Canonical Resource Baseline

Domain	Resources
Case	Case, InvestigationQuestion/CharterVersion, Gate (with GateDecision history), Task (with history), CaseActivity projection [v0.1.4 · CR-N-01]
Evidence	Source, EvidenceItem, EvidenceExtract, Derivative/Lineage, DerivedText [v0.1.4 · CR-N-09], Claim, Fact, VerificationDecision [v0.1.1 · A10]
Identity	Entity, Identifier/Alias, MatchCandidate, ResolutionDecision (v0.1 name: MergeDecision) [v0.1.1 · ER]
Relations/ assets	Relationship, OwnershipInterest, ControlAssertion, Asset
Time/value	Event, Timeline projection, ValueFlow, ValueFlowLeg
Analysis	Indicator, Typology, TypologyMatch, Hypothesis, IntelligenceGap, Assessment
Products	IntelligenceProduct, ProductVersion, Review, Dissemination, ExportPackage, SharingLog
Governance	Vocabulary, RetentionPolicy (RetentionRule), LegalHold, DispositionRecord, HandlingChange, CaseMembership, AuditEvent, Job [v0.1.3 · CR-I7-03, CR-I7-04, CR-I6-12]

Annex B — Request Review Checklist

- Is the canonical resource and case/context scope explicit?
- Does the endpoint preserve unknown/inference/candidate/value-flow class semantics?
- What authorization and non-disclosure behavior applies?
- Is a version token/precondition required?
- Could a retry duplicate a high-impact action; is idempotency needed?
- What audit event/correlation must be emitted?
- Could error details leak protected content?
- Are pagination/filter/sort fields allowlisted?

- Does the response include only the minimum authorized data needed?
- Is this canonical data or a derived projection, and is that distinction explicit?